HealthTrack-X: DPP-Regulierungsbewertung

Technische Ist-Analyse des Repository-Stands | Stand: 17. September 2026 | Bewertungsgegenstand: Plattform, Backend, NX-Export und DPP-Datenaustausch

Gesamtbewertung: HealthTrack-X ist als technische DPP-Basis **substanziell vorbereitet**, erfüllt aber derzeit nicht nachweisbar alle regulatorischen Anforderungen für einen produktiven, verbindlichen Digital Product Passport. Besonders gut abgedeckt sind strukturierte Produktdaten, Material- und Baugruppeninformationen, AAS/JSON-LD-Interoperabilität, CRMA-Anreicherung, Versionierung und ein grundsätzlich vorhandener OIDC/Keycloak-Zugriffsschutz. Die Freigabe als produktiver DPP-Dienst setzt vor allem verpflichtende Authentifizierung, sichere Transportwege, fein granulare Datenrechte, belastbare Identität/Resolver, signierte beziehungsweise revisionssichere Nachweise und produktspezifische Pflichtfeldsets voraus.

Technische Reife: mittel

Viele Kernbausteine vorhanden, mehrere produktionskritische Kontrollen offen

Regulatorischer Status: teilweise

ESPR-Rahmen unterstützt; konkrete Pflichten hängen vom delegierten Rechtsakt ab

Höchstes Risiko: Zugriff & Vertrauen

Auth optional, NX über HTTP, EDC-TLS-Prüfung deaktiviert

Gut abgedeckt **Teilweise / konfigurationsabhängig** **Gap / Nachweis fehlt**

Gegenüberstellung: Anforderung und Einschätzung

Anforderung / Kontrollziel	Vorhandene Umsetzung in HealthTrack-X	Einschätzung	Gap, Risiko oder Nachweisbedarf	Technische Belege
Eindeutige Produktidentität Produkt, Modell, Version und Beziehung müssen eindeutig auflösbar sein.	Produkt-IDs, NX-IDs, GitHub-Blob-/Raw-URLs, AAS-IDs und Parent-Child-BOM-Strukturen.	**Teilweise**	Repository-/Branch-gebundene URLs sind kein unabhängiger, dauerhafter DPP-Resolver. Betreiber-, Hersteller- und Anlagen-IDs sind nicht einheitlich als eigenes Identitätsmodell erkennbar.	main.py; export_nx_to_htx.py
Daten-Carrier und Resolver QR/NFC/RFID oder vergleichbare maschinenlesbare Verknüpfung zum DPP.	API- und Web-Endpunkte sind vorhanden; NX öffnet nach Export die Strukturansicht.	**Gap**	Kein nachgewiesener QR-/NFC-Carrier, keine Resolver-Strategie bei Anbieter-, Repository- oder Produktwechsel und kein dokumentiertes Availability-/Fallback-Konzept.	NX-Export; API-Routen
Maschinenlesbare und interoperable Daten Strukturiert, standardbasiert, exportierbar und ohne Vendor Lock-in.	JSON, JSON-LD, AAS/BaSyx, IDTA-Semantik sowie EDC-/Tractus-X-Anbindung.	**Gut abgedeckt**	Semantische IDs, Kontextversionen, Pflichtfelder und Konformität je Produktgruppe müssen mit verbindlichen Testfällen nachgewiesen werden.	main.py; edc_connector.py

Anforderung / Kontrollziel	Vorhandene Umsetzung in HealthTrack-X	Einschätzung	Gap, Risiko oder Nachweisbedarf	Technische Belege
Materialzusammensetzung und Stoffinformationen	CAS-Nummern, chemische Zusammensetzung, Elementanteile, Materialklassifikation und CRMA-Prüfung.	**Teilweise**	Quellen, Mess-/Berechnungsmethode, Zeitstempel, Konfidenz, Grenzwerte und produktspezifische Gefahrstoffanforderungen sind nicht einheitlich verpflichtend modelliert.	crma_checker.py; main.py
Nachhaltigkeits- und Carbon-Daten	Recyclinganteil, CO2-Äquivalent und Berechnungsmethode; AAS-Sustainability-Submodelle.	**Teilweise**	Keine ausreichende Evidenz für Prüfstatus, Systemgrenzen, Norm, Datensatzversion, Bilanzierungszeitraum oder unabhängige Verifizierung.	main.py
BOM, Komponenten und Lebenszyklus	Siemens-NX-Extraktor, Hierarchie, Mengen, Masse, Volumen, Dichte, Oberfläche und Materialattribute.	**Teilweise**	Reparatur, Demontage, Wiederverwendung, Recyclinganleitung, Ersatzteile, Sicherheits- und Rückrufinformationen sind nicht als vollständiges Lifecycle-Modell erkennbar.	export_nx_to_htx.py
Authentifizierung Nur berechtigte Teilnehmer erhalten geschützte DPP-Funktionen.	Keycloak/OIDC, Bearer-JWT, RS256, JWKS, Issuer-/Audience-Prüfung und Rollenextraktion.	**Konfigurationsabhängig**	**AUTH_ENABLED ist standardmäßig false.** Ohne harte Produktionsprüfung kann die gesamte API ohne Authentifizierung betrieben werden.	auth.py
Autorisierung und Zugriffsebenen Unterschiedliche Rechte für Hersteller, Lieferanten, Behörden, Recycler und Öffentlichkeit.	Rollen viewer, editor, admin, service; Admin-Schutz und Benutzerfreigabe über Keycloak.	**Teilweise**	Keine nachgewiesene fein granulare Autorisierung nach Organisation, Produkt, Submodell, Zweck oder Feld. Sensible Lieferketteninformationen könnten zu breit sichtbar sein.	auth.py; main.py
Sichere Übertragung und Vertrauensbeziehung	GitHub-App-/Token-Anbindung und EDC-API-Konfiguration sind vorhanden.	**Kritischer Gap**	NX sendet an `http://htx.local` ohne sichtbaren Token. EDC verwendet `verify=False`. Damit fehlen in diesen Pfaden belastbare Vertraulichkeit und Serverauthentizität.	export_nx_to_htx.py; edc_connector.py
Integrität, Provenienz und Authentizität	Git-Versionierung, SHA-Konflikterkennung, Änderungs-Diff, Preview und Approval vor Commit.	**Teilweise**	Kein nachgewiesenes signiertes DPP/AAS, keine Trust Chain, keine Feld-Provenienz mit Quelle/Methode/Zeitstempel und keine unveränderliche Auditspur. `requested_by` darf nicht aus dem Client-Request stammen.	main.py
Datenqualität und Pflichtfelder	Dynamische Pydantic-/YAML-Schemata, Typen, Bereiche, Pattern und Enum-Prüfungen.	**Teilweise**	Felder sind grundsätzlich optional. Je Produktgruppe fehlen verbindliche Pflichtfeldsets, Vollständigkeitsstatus und fachliche Plausibilitätsregeln vor Veröffentlichung.	schema_validator.py
Dataspace- und Vertragszugriff	EDC-Kataloge, Policies, Vertragsdefinitionen, Negotiations und Transfers.	**Teilweise**	Technische EDC-Funktionalität ersetzt keine vollständige Identitäts-, Zertifikats-, Policy- und Teilnehmer-Governance eines produktiven Dataspaces.	edc_connector.py
Datenschutz und Vertraulichkeit	OIDC-Claims, Rollen und getrennte Datenquellen sind technisch berücksichtigt.	**Nachweis fehlt**	Kein erkennbares DPP-Datenschutzkonzept zu Datenminimierung, Zweckbindung, Aufbewahrung, Löschung, Betroffenenrechten und Trennung personenbezogener Daten.	auth.py; main.py

Anforderung / Kontrollziel	Vorhandene Umsetzung in HealthTrack-X	Einschätzung	Gap, Risiko oder Nachweisbedarf	Technische Belege
Verfügbarkeit, Aktualität und Widerruf	Memory-/Disk-/GitHub-Caches, Status-Endpunkte und Repository-Versionen.	**Teilweise**	Keine dokumentierten SLA, Wiederherstellungsziele, DPP-Widerrufs-/Ablaufzustände, Cache-Invalidierungsregeln für externe Resolver oder öffentliche Betriebsüberwachung.	main.py
Batteriepass / produktspezifische Rechtsakte	Allgemeine Material-, Nachhaltigkeits- und CRMA-Daten sind anschlussfähig.	**Nicht nachgewiesen**	Eigenes Batteriepass-Modell mit Batterie-ID, Produktionsdaten, Kapazität, State of Health, Carbon Footprint, Recycling und rollenbezogenem Zugriff fehlt beziehungsweise ist nicht belegt.	Produktmodell prüfen

Authentifizierung und Zugriffsschutz: Detailbewertung

Die Authentifizierungsarchitektur ist grundsätzlich passend für einen DPP-Dienst: OIDC/Keycloak, signierte JWTs, JWKS und Rollenprüfung sind implementiert. Für eine regulatorisch belastbare Umgebung muss jedoch der sichere Betriebsmodus technisch erzwungen werden, statt ihn nur über Umgebungsvariablen zu ermöglichen.

> **Priorität 1:** Produktionsstart abbrechen, wenn `AUTH_ENABLED` nicht aktiv ist oder Issuer, Audience und JWKS fehlen. Öffentliche Pfade auf Status- und notwendige Resolver-Funktionen begrenzen.

> **Priorität 1:** NX-Export auf HTTPS beziehungsweise mTLS umstellen und einen kurzlebigen Service-Token oder einen signierten Upload-Request verwenden. Idempotency-Key und Request-ID gegen Wiederholungsduplikate ergänzen.

> **Priorität 1:** EDC-Zertifikatsprüfung aktivieren und `verify=False` entfernen. CA-Bundle, Zertifikatsrotation und getrennte Development-/Production-Konfiguration einführen.

> **Priorität 2:** Autorisierung als Policy-Modell ausdrücken: Organisation, Rolle, Produkt, Submodell, Zweck, Datenklassifikation und Ablaufzeit.

> **Priorität 2:** Auditdaten serverseitig aus dem validierten Token erzeugen. Freigaben, Ablehnungen, Widerrufe, Exportversionen und Signaturstatus unveränderlich protokollieren.

Priorisierte Umsetzung

Priorität	Maßnahme	Erwarteter Effekt
P1	Auth verpflichtend, HTTPS/mTLS, EDC-TLS-Prüfung, NX-Service-Authentifizierung	Schließt die unmittelbarsten Vertraulichkeits-, Identitäts- und Manipulationsrisiken.
P1	Produkt-, Hersteller-, Betreiber- und Facility-IDs sowie dauerhaften DPP-Resolver definieren	Stabile Identität und regulatorisch nachvollziehbare Auflösung.
P2	ABAC-/Policy-Modell für Rollen, Organisationen, Submodelle und Datenklassen	Kontrollierter Zugriff auf öffentliche und vertrauliche DPP-Daten.
P2	Signierte DPP-Versionen, Provenienz und unveränderliches Audit	Nachweis von Herkunft, Integrität, Freigabe und Änderungshistorie.
P2	Verbindliche Pflichtfeldsets je Produktgruppe und Veröffentlichungsgate	Verhindert unvollständige DPPs; ermöglicht delegierte Rechtsakte.
P3	Batteriepass sowie Reparatur-, Demontage-, Gefahrstoff- und Recyclingmodelle	Erweiterbarkeit für konkrete Produktgruppen und spätere Pflichten.

Bewertungsgrundlage

Regulatorischer Rahmen: Verordnung (EU) 2024/1781 über die Schaffung eines Rahmens für die Festlegung von Ökodesign-Anforderungen für nachhaltige Produkte (ESPR), insbesondere DPP-Regelungen; Verordnung (EU) 2023/1542 über Batterien und Altbatterien, einschließlich Batteriepass. Die konkrete Pflichtdatenmenge und die betroffenen Produkte hängen vom jeweils geltenden delegierten Rechtsakt ab.

Technische Repository-Belege: `backend/auth.py`, `backend/main.py`, `backend/schema_validator.py`, `backend/edc_connector.py`, `backend/crma_checker.py` und `backend/scripts/export_nx_to_htx.py`. Diese Bewertung ist eine technische Gap-Analyse und keine Rechtsberatung oder formale Konformitätsbescheinigung.